

NIST Cybersecurity Framework (CSF) 2.0

Gap Assessment - Executive Report

NorthStar Financial Services

Project Type	Self-directed simulated GRC portfolio assessment
Framework	NIST Cybersecurity Framework (CSF) 2.0
Assessment Scope	8 selected CSF outcomes across Govern, Identify, Protect, and Detect
Current / Target Tier	Tier 2 - Risk Informed / Tier 3 - Repeatable

Disclaimer: NorthStar Financial Services is a fictional organization created solely for this portfolio project. All evidence, findings, risk ratings, and recommendations are simulated for educational purposes and do not represent a real client assessment.

1. Executive Summary

This assessment applies selected NIST CSF 2.0 outcomes to a simulated Canadian financial services organization with approximately 180 employees, Microsoft 365, Active Directory, cloud applications, remote staff, customer financial information, and a six-person IT team.

NorthStar has several established cybersecurity practices, including multi-factor authentication for key services, monthly vulnerability scanning, nightly backups, security logging, an information security policy, and an incident response plan. The assessment also identified areas where practices are incomplete, reactive, outdated, or not consistently evidenced.

The overall simulated Tier assessment is **Tier 2 - Risk Informed**, with **Tier 3 - Repeatable** as the target. The primary improvement theme is moving from controls that exist but are inconsistently reviewed or maintained toward formal, repeatable, evidence-supported processes.

Risk Rating	Findings	Examples
High	5	Privileged access, backup restoration, vulnerability tracking, network monitoring, incident response
Medium	3	Asset inventory, legacy authentication, policy maintenance

2. Scope and Methodology

The assessment reviewed eight selected CSF outcomes covering hardware asset management, authentication, privileged access, backup restoration, vulnerability management, network monitoring, cybersecurity policy maintenance, and incident response planning.

Assessment flow: Evidence -> Current State -> Gap -> Risk -> Target State -> Recommended Action -> Priority

Risk was considered using a simplified qualitative Low / Medium / High likelihood-and-impact approach for this learning project. Ratings were based only on the simulated evidence available; unsupported assumptions were intentionally avoided.

3. Key Findings

PR.AA-05 - Privileged Access	High
Observation	Fourteen highly privileged accounts exist. Reviews occur when employees leave or change departments, but there is no scheduled certification process.
Recommended action	Establish periodic privileged-access reviews, require appropriate owner certification, remove unnecessary privileges, and retain review evidence.
PR.DS-11 - Backup Restoration	High
Observation	Critical servers are backed up nightly and individual files have been restored, but no documented testing schedule exists and the last full restoration test was approximately 18 months ago.
Recommended action	Implement risk-based restoration testing, document results, remediate issues, and retain testing evidence.
ID.RA-01 - Vulnerability Management	High
Observation	Monthly scanning is performed, but findings are not centrally tracked, remediation deadlines are not formally defined, and some findings recur.
Recommended action	Create centralized vulnerability tracking with ownership, status, severity, dates, risk-based remediation expectations, and escalation.
DE.CM-01 - Network Monitoring	High
Observation	Firewall and endpoint telemetry exist, but logs are generally reviewed after a problem is reported rather than through a formal proactive monitoring process.
Recommended action	Establish ongoing monitoring, alert investigation responsibilities, and escalation procedures.
ID.IM-04 - Incident Response Planning	High
Observation	An incident response plan exists, but it has never been formally exercised, contacts are outdated, and cloud-provider responsibilities are unclear.
Recommended action	Exercise and update the plan, clarify responsibilities, refresh contacts, and incorporate lessons learned.
ID.AM-01 / PR.AA-03 / GV.PO-02	Medium
Observation	Additional gaps were identified in hardware inventory reconciliation, authentication for three legacy applications, and cybersecurity policy maintenance.
Recommended action	Address these through improved asset reconciliation, risk-based authentication decisions, and a formal policy review and update process.

4. CSF Tier Assessment

State	Tier	Rationale
Current	Tier 2 - Risk Informed	Cybersecurity practices exist and risk is recognized, but practices are not consistently formalized, reviewed, maintained, or evidenced across the organization.
Target	Tier 3 - Repeatable	Policies and processes should become formal, consistently implemented, reviewed, maintained, and supported by repeatable evidence across the organization.

5. Prioritized Remediation Roadmap

Priority	Initiative	Expected Evidence
High	Formalize periodic privileged-access certification.	Access review records, approvals, revocation evidence
High	Perform risk-based backup restoration testing.	Test results, issues, remediation records
High	Centralize vulnerability tracking and remediation follow-up.	Vulnerability register, ownership and closure evidence
High	Establish proactive network monitoring and escalation.	Monitoring procedure, alert and escalation records
High	Exercise and maintain the incident response plan.	Exercise report, updated plan, lessons learned
Medium	Improve asset reconciliation, legacy authentication, and policy review.	Reconciled inventory, authentication assessment, approved policy updates

6. Conclusion

The simulated assessment indicates that NorthStar has a meaningful cybersecurity foundation but would benefit from greater consistency, formalization, testing, evidence retention, and proactive monitoring. The remediation roadmap prioritizes practices where weaknesses could have significant operational or security consequences while maintaining a risk-based approach rather than treating every gap as equally urgent.

Portfolio note: This report is intended to demonstrate practical application of NIST CSF 2.0 concepts, including evidence review, current- and target-state analysis, gap identification, qualitative risk assessment, remediation planning, and CSF Tier assessment.

Reference: National Institute of Standards and Technology (NIST), *The NIST Cybersecurity Framework (CSF) 2.0*, 2024.